LABORATUVAR 1 · PAKETPRO 3000 · MİR250 AMR

Safety Architecture

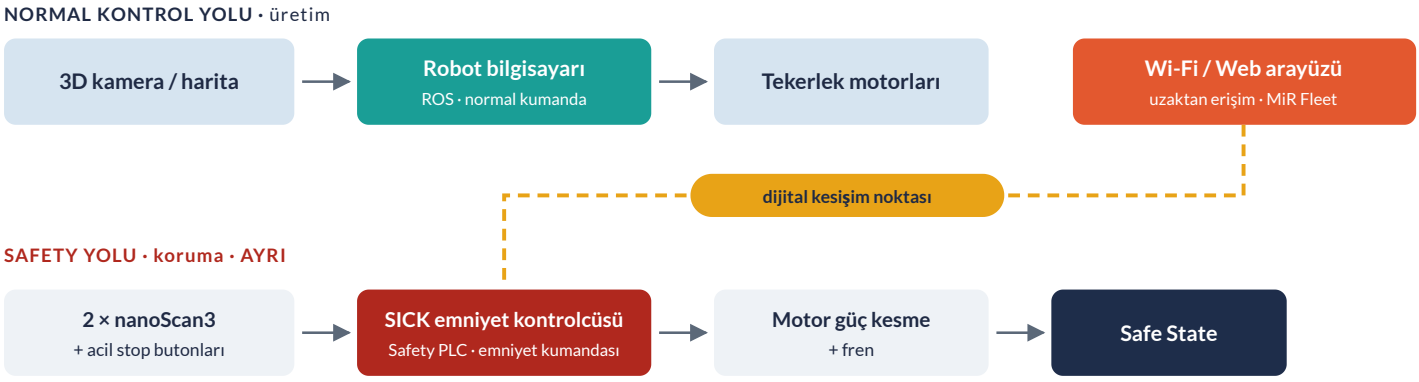
Çıktı: Safety Function Map

Ad Soyad Betül Altunyuva 235542020 | Grup Gece-B | Tarih 23.10.2026

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve ayrı bir safety yolunda yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, dijital bir konfigürasyona bağlıdır.

Makine bağlamı

MiR250, 250 kg'a kadar yük taşıyan, 2 m/s hıza çıkan otonom mobil robot; yaya ve forkliftlerle aynı koridoru paylaşır. İnsanı koruyan zincir **2 × SICK nanoScan3 lazer tarayıcı + acil stop → SICK emniyet kontrolcüsü → motor gücünü kesme**'dir. Koruma alanı, hız sınırı ve susturma (muting) ayarları **Wi-Fi ve web arayüzü üzerinden değiştirilebilen dijital ayarlardır** — sorular oraya gidecek.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Hareket eden robot ve yükü: 97 kg gövde + 250 kg'a kadar yük, 2 m/s'ye kadar hız. Yayaya **çarpma**; robotla duvar/raf arasında **sıkışma ve ezilme**; ayağın tekerlek altında kalması; devrilen/düşen yük (ISO 12100: mekanik tehlike).

2 Safety function (emniyet fonksiyonu) hangisidir?

SF-1 insan algılama: tarayıcının koruma alanında biri görülürse robot durur · **SF-2** acil durdurma (butonlar) · **SF-3** aşırı hız önleme · **SF-4** hıza göre koruma alanını büyütme.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki alt (kırmızı) yol, robot gövdesinin içinde: iki nanoScan3 tarayıcı (ön ve arka köşe) + acil stop butonları → SICK emniyet kontrolcüsü → motor gücünü kesme + fren. Robot bilgisayarı (ROS) bu zincirin **dışında**.

4 Normal PLC ile Safety PLC farkı nedir?

Robot bilgisayarı rota ve hız kararı verir; hata yaparsa robot yanlış yere gider. Emniyet kontrolcüsü yalnızca "durmalı mıyım" sorusuna bakar, çift kanallıdır ve kendi hatasını fark edince robotu güvenli duruma geçirir.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

Güvenilirlik riskle orantılı olsun diye. Koridorda çarpma: S2 (ciddi) · F2 (yayalar gün boyu) · P2 (kör köşede kaçmak zor) → ISO 3691-4 / ISO 13849'a göre **PLr d**. Üreticinin PL beyanı kılavuzdan doğrulanmalı.

6 Safe state (güvenli durum) nedir?

Robot **durmuş**, motorların sürüş gücü kesilmiş, **frenler devrede**. Koruma alanı temizlenene ya da operatör onaylayana kadar kendiliğinden hareket etmez.

7 Safety function hangi dijital bağımlılıklara sahip?

Tarayıcıdaki koruma alanı boyutları ve **susturma (muting)** bölgeleri; emniyet kontrolcüsündeki hız sınırı ve alan geçiş ayarları; **emniyet kontrolcüsü parolası**; haritadaki yavaş/yasak bölgeler ve robot yazılımının sürümü (2.10.2.1 öncesi CISA ICSA-21-280-02 kapsamında).

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Robot Wi-Fi'ı ve web arayüzünde **varsayılan parolalar** (CVE-2020-10269, CVE-2020-10270; kılavuzda yazılı) kullanılıyorsa yetkisiz biri koruma alanı, hız ya da susturma ayarlarına ulaşabilir → SF-1/SF-3 zayıflar. Haziran 2020 öncesi robotlarda emniyet kontrolcüsünün varsayılan parolası (**CVE-2020-10276**) acil durdurmayı da etkileyebilir. [V — test edilmedi]

LABORATUVAR 2 · PAKETPRO 3000 · MİR250 AMR

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Betül Altunyuva 235542020 | Grup Gece-B | Tarih 23.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Robot bilgisayarı (ROS) · **Emniyet kontrolcüsü (Safety PLC)** · 2 × nanoScan3 lazer tarayıcı · 2 × 3D kamera · acil stoplar · web arayüzü (port 80) · robotun dahili Wi-Fi erişim noktası · MiR Fleet sunucusu · operatör tableti · üretici servisinin uzak erişimi · MiR Charge 48V şarj istasyonu · Ethernet ve USB portu · ofis ağı (ERP/e-posta)

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

- **Z0 Kurumsal IT:** ofis ağı (ERP, e-posta)
- **Z1 DMZ:** uzak erişim için jump server, güncelleme sunucusu
- **Z2 Filo yönetimi:** MiR Fleet sunucusu, operatör tableti, robotlara ayrılmış fabrika Wi-Fi'ı
- **Z3 Robot kontrol:** robot bilgisayarı, web arayüzü, dahili Wi-Fi, 3D kameralar, şarj istasyonu
- **Z4 Robot emniyet:** emniyet kontrolcüsü, iki lazer tarayıcı, acil stoplar, motor gücünü kesen devre

2 Robotun dışa açık uzak erişimi (kendi Wi-Fi'ı ve üretici servisi) hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Robotun kendi Wi-Fi erişim noktası ve web arayüzü Z3'tedir; üretici servisinin uzak erişimi dışarıdan (internet) gelir. **Kalamaz:** doğrudan, varsayılan parolalı erişim kabul edilemez. Üretici erişimi yalnız DMZ'deki jump server üzerinden (VPN + MFA) açılmalı; robotun kendi AP'si kapatılmalı ya da parolası değiştirilmelidir.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

- **Z0 → Z1:** güvenlik duvarı, ofisten robota doğrudan trafik yok
- **İnternet → Z1 (üretici servisi):** VPN, MFA, kişisel hesap, oturum kaydı, varsayılan kapalı
- **Z1 → Z2:** sadece jump server'dan Fleet'e, sadece gerekli portlar
- **Z2 → Z3 (Wi-Fi):** robot için ayrı, kurumsal kimlik doğrulamalı Wi-Fi; robotun kendi erişim noktası kapalı ya da parolası değiştirilmiş
- **Z3 → Z4:** emniyet ayarları yalnızca yerinde, yetkili kişiyle ve kayıtlı olarak değişir; robot bilgisayarı yalnızca onaylı alan setini seçebilir
- **Ethernet / USB portu:** fiziksel kapak, USB'den açılış kapalı, BIOS parolası

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — servis robota ya da Fleet'e doğrudan ulaşmaz; tüm erişim tek noktadan geçer ve orada kesilebilir.
Tünel?	Açık / VPN	**VPN** — trafik şifrelenir, robot ve Fleet internete açılmaz.
Kimlik?	Parola / MFA	**MFA** — kılavuzda yazan ya da sızan bir parola tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kimin ne yaptığı izlenir, ayrılan teknisyenin hesabı tek başına kapatılır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — "emniyet ayarına kim dokundu" sorusu cevaplanır; olayda kanıt olur.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — erişim talep üzerine ve süreli açılır, kalan zamanda kapı kapalıdır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · MİR250 AMR

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Betül Altunyuva 235542020 | Grup Gece-B | Tarih 23.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç.** Skor = L × S × E (her biri 1–3).
Kural: S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

MiR250'nin kapıları (ipucu)

Varsayılan parolalı robot Wi-Fi'ı · web arayüzü (port 80) ve paylaşılan hesap · emniyet kontrolcüsü parolası · üretici servisinin uzak erişimi · Ethernet/USB portu — *fiziksel sonuç adayları: yayaya çarpma, raf ile robot arasında sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R-01 Fırsatçı dış saldırgan → varsayılan parolalı robot Wi-Fi'ı → web arayüzünde koruma alanı küçülür / hız sınırı yükselir → robot yayayı zamanında algılayıp duramaz, çalışana çarpar (ağır yaralanma)	3	3	3	27	Kritik S3
R-02 Meraklı içeriden → paylaşılan web arayüzü hesabı → dar bir geçişe gereksiz susturma bölgesi tanımlanır → robot orada tarayıcıyı susturur, çalışanı raf ile robot arasında sıkıştırır (ezilme)	2	3	2	12	Yüksek S3
R-03 Tedarik zinciri → üretici servisinin uzak erişimi → güncellemeyle hatalı harita/bölge dosyası yüklenir → yasak bölge kalkar, robot yaya yoğun alana girer, çarpar	2	3	1	6	Orta S3

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

Puan gerekçeleri

R-01: L=3 parola kılavuzda yazılı (CVE-2020-10269/10270) · S=3 350 kg'lık kütleyle çarpma ağır yaralanmadır · E=3 robotun Wi-Fi'ı sürekli yayın yapar.
R-02: L=2 parola gerekir ama paylaşılan hesap herkesin elindedir · S=3 ezilme ağır yaralanmadır · E=2 yalnızca fabrika ağından erişilir.
R-03: L=2 servisin hesabı ele geçirilmeli · S=3 çarpma · E=1 erişim varsayılan kapalı, yalnızca talep üzerine açılır.

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   R-01, çünkü kapı hem çok kolay (varsayılan parola) hem sürekli açık (Wi-Fi) ve sonucu bir insanın ağır yaralanması; skor 27 ile Kritik bantında.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, R-03 (skor 6, Orta). S3 bayrağı alır, ayrı bir yönetim listesinde tutulur ve en az bir önlem ya da yazılı kabul kararı olmadan kapatılmaz.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar? Üç senaryonun üçü de fiziksel sonuçla (çarpma, ezilme) bitti.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · MİR250 AMR

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad Betül Altunyuva 235542020 | Grup Gece-B | Tarih 23.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: robotun Wi-Fi'ı ve web arayüzü bugün varsayılan parolalarla açık.

- Robot ve Fleet'e fabrika ağından ve robotun kendi Wi-Fi'ından doğrudan ulaşılıyor
- Web arayüzü ve emniyet kontrolcüsü varsayılan, paylaşılan parolalarla
- Tek faktörlü giriş
- Üretici servisinin erişimi sürekli açık
- Kimin ne değiştirdiği bilinmiyor

HEDEF (beş ilkeyle yeniden tasarlayın)

Makine → jump server → VPN → MFA → kişisel hesap → kayıt

- **Ara nokta:** servis yalnızca DMZ'deki jump server'dan girer; robotun kendi Wi-Fi erişim noktası kapalı
- **Kişisel hesap:** herkese ayrı hesap; varsayılan parolalar ilk kurulumda değişir
- **İkinci faktör:** uzak erişim ve yönetici hesapları için MFA
- **Varsayılan kapalı:** talep üzerine açılır, süre dolunca kapanır
- **Oturum kaydı:** uzak oturumlar ve emniyet ayarı değişiklikleri kayıtlı

Ek: robot yazılımı güncel sürüme (en az 2.10.2.1) yükseltilir ve robotlar için ayrı bir Wi-Fi ağı kurulur.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Bugünkü tasarımda evet. Koruma alanı, hız sınırı ve susturma bölgeleri robot bilgisayarı üzerinden değiştirilebilen dijital ayarlardır. Emniyet kontrolcüsü donanım olarak ayrı olsa da ayarlarına ağ üzerinden ulaşılabildiği sürece insanı koruyan fonksiyon zayıflayabilir.

2. Lazer tarayıcı (insan algılama) zincirinin uzak erişim yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   - Uzak erişim, Wi-Fi ya da web arayüzü üzerinden gelen hiçbir komut/ayar koruma alanını küçültememeli, hız sınırını yükseltememeli ve acil durdurmayı devre dışı bırakamamalıdır.
   - Bu ayarlar yalnızca yerinde, onaylı ve kayıtlı olarak değişmeli; susturma bölgeleri emniyet sorumlusunun onayı olmadan devreye girmemelidir.
   - Bakım yolu ele geçirilse de lazer tarayıcı → emniyet kontrolcüsü → motor güç kesme zinciri çalışmaya devam etmelidir (PLr d).

R-01 için etki (LAB 3'ten)

Bugün L3·S3·E3 = 27 Kritik → erişim önlemleriyle L1·S3·E2 = 6 Orta (S3 bayrağı sürer) → emniyet bağımsızlığıyla L1·S1·E2 = 2 Düşük. Erişim önlemleri L ve E'yi düşürür; S'yi yalnızca emniyet tasarımı düşürür.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.